

Bagus. Setelah peserta memahami **Easy (backup leak → credential → SUID)**, level **Medium** sebaiknya mulai mengajarkan **rantai eksploitasi yang lebih panjang**, di mana peserta harus menggabungkan beberapa temuan sebelum mendapatkan root.

Boot2Root Medium - "DevBox"

Tingkat Kesulitan

Medium

Materi yang Dipelajari

- Service Enumeration
 - Web Enumeration
 - Local File Inclusion (LFI)
 - Credential Discovery
 - Credential Reuse
 - SSH Access
 - sudo Misconfiguration
 - Privilege Escalation
 - Basic Linux Enumeration
-

Alur Penyelesaian

Nmap

↓

Web Enumeration

↓

LFI

↓

Membaca Config File

↓

Menemukan Credential

↓

SSH Login

↓

Enumerasi sudo

↓

Misconfigured sudo Rule



Root

Topologi

Sistem

- Ubuntu Server 22.04
- Hostname: devbox

User

developer

Password (disembunyikan dari peserta):

DevPass2025!

Service yang Dibuka

Port Service

22 SSH

80 Apache

Website

Landing page:

<h1>Developer Portal</h1>

Tambahkan fitur:

/view.php?page=

Contoh:

http://target/view.php?page=about.php

Kerentanan

LFI (Local File Inclusion)

Aplikasi memasukkan file berdasarkan parameter page tanpa validasi yang memadai.

Konsep yang ingin diajarkan:

- memahami path traversal

- memahami risiko membaca file lokal
- menemukan informasi sensitif dari konfigurasi aplikasi

Peserta diharapkan menyadari bahwa file konfigurasi aplikasi dapat diakses melalui LFI dan berisi kredensial.

Konfigurasi Aplikasi

Buat:

/var/www/config/db.php

Isi:

```
<?php
```

```
$dbuser="developer";
```

```
$dbpass="DevPass2025!";
```

```
?>
```

Credential Reuse

Gunakan password yang sama untuk:

developer

dan

SSH

Ini mengajarkan bahaya penggunaan ulang password.

User Flag

Lokasi:

/home/developer/user.txt

Isi:

```
FLAG{developer_access}
```

Privilege Escalation

sudo Misconfiguration

Misalnya user developer diizinkan menjalankan program tertentu sebagai root tanpa password.

Konsep pembelajaran:

- peserta melakukan enumerasi hak sudo
- memahami bahwa tidak semua program aman dijalankan sebagai root
- mempelajari bagaimana fitur program tertentu dapat disalahgunakan

Daripada memberi langkah eksploitasi rinci, tantangan dapat diarahkan dengan petunjuk:

Developer can run one maintenance utility as root.

dan peserta diminta meneliti implikasinya.

Root Flag

/root/root.txt

Isi:

FLAG{devbox_root}

Petunjuk yang Dapat Ditemukan

File:

/opt/README.txt

Isi:

Remember to check your sudo permissions.

Enumerasi yang Diharapkan

Tahap 1

Peserta menemukan:

22/tcp

80/tcp

Tahap 2

Menemukan parameter:

page=

Tahap 3

Menemukan LFI.

Tahap 4

Membaca konfigurasi aplikasi.

Tahap 5

Mendapat kredensial developer.

Tahap 6

Login SSH.

Tahap 7

Enumerasi:

sudo permissions

Tahap 8

Mendapat root.

Pelajaran yang Didapat

Peserta belajar bahwa:

1. Kerentanan web tidak selalu langsung menghasilkan shell.
2. File konfigurasi sering berisi informasi sensitif.
3. Credential reuse sangat berbahaya.
4. Enumerasi setelah mendapatkan user shell sama pentingnya dengan enumerasi awal.
5. Salah konfigurasi sudo dapat mengakibatkan eskalasi hak akses.

Variasi Medium Lain

Setelah menyelesaikan "DevBox", Anda bisa membuat beberapa mesin medium dengan fokus berbeda:

Medium 1 — LFI → Credential Reuse → sudo

Kesulitan: ★★☆☆☆

Medium 2 — SMB Share → Password Leak → SSH → SUID

Kesulitan: ★★☆☆☆

Medium 3 — Git Exposure → Source Code Leak → DB Credentials → SSH → sudo

Kesulitan: ★★★☆☆

Medium 4 — Backup File → Web Shell → User → Cron Misconfiguration

Kesulitan: ★★★☆☆

Medium 5 — Docker Group Abuse → Root

Kesulitan: ★★★★★

Ini memberi progres yang cukup natural sebelum masuk ke level Hard yang melibatkan CVE, capabilities, container escape dalam lab, atau rantai eksploitasi multi-tahap yang lebih kompleks.